



File No.: EXP202309055

Sanctioning Procedure No. PS/00497/2023

## RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

### FACTUAL BACKGROUND

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on May 15, 2023. The complaint is initially directed against B.B.B.

The complainant states that they registered to participate in a popular race organized by the City Council of San Cristóbal de La Laguna, and that on April 20, 2023, they received an email from the email address \*\*\*EMAIL.1, in which the signature footer indicated the respondent B.B.B., under the subject "Schedule for collecting bib numbers XXII half marathon city of La Laguna 2023," which "made public the email addresses of all participants/registrants by putting all email addresses in the 'To' field instead of in the 'Bcc' field, so I have received emails from other participants in the race, making it clear that my email address has been published without my consent and any of the registrants in the race can use it. When I contacted him, he only limited himself to apologizing."

Along with the notification, the following is provided:

- Email dated April 20, 2023, sent to 493 visible email recipients, regarding the "Schedule for collecting bib numbers XXII half marathon city of La Laguna 2023," referred to by the complainant.
- Email dated April 23, 2023, in which the complainant responds to the previous email, asking for explanations regarding why their email address has been published.
- Email dated April 24, 2023, responding to the previous one, in which apologies are offered, indicating that it was a significant error that needs to be resolved.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the person against whom the complaint is directed, who appears in the signature footer of the emails provided by the complainant, Mr. B.B.B., so that he could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was received on August 31, 2023, as recorded at C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/16

acknowledgment of receipt that is part of the file, without any response having been received to this written communication.

THIRD: On August 15, 2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the complainant was admitted for processing, which was communicated to them.

FOURTH: On May 8, 2024, a diligence was issued to record and attach to the present procedure the following documents generated by the Subdirectorate of Data Inspection, obtained from the website of the Autonomous Sports Organization of the City Council of San Cristóbal de La Laguna, www.deportelagunero.com, attached to this diligence as Annex I, II, and III, with the content of the same being considered proven for the purposes of this file:

- Annex I. Municipal regulation applicable to the XXII half marathon of the city of La Laguna.
- Annex II. Privacy policy of the website.
- Annex III. Announcement of the call for the XXII half marathon of the city of La Laguna.

In light of the above, and due to the fact that the email through which the complaint is submitted refers to aspects related to the practical development of the race, the organization of which corresponds to the City Council of San Cristóbal de La Laguna, this entity, in its capacity as responsible party, is identified as the respondent.

FIFTH: On May 13, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the City Council of San Cristóbal de La Laguna (hereinafter, the CITY COUNCIL), as the data controller of the personal data of the participants registered in the aforementioned race, for the alleged commission of the infringements of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified in Article 83.5.a) of the GDPR and Article 83.4.c) of the GDPR.

SIXTH: The aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), and after the period granted for the submission of allegations had elapsed, it has been confirmed that no allegations have been received from the respondent.

Article 64.2.f) of the LPACAP -a provision of which the respondent was informed in the initiation agreement- establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the responsibility attributed, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts on which the accusation was based, the infringement of the GDPR attributed to the respondent, and the sanction that could be imposed. Therefore, considering that the respondent has not submitted allegations to the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case a proposal for resolution.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/16

In view of all the actions taken by the Spanish Agency for Data Protection in the present procedure, the following facts are considered proven,

#### PROVEN FACTS

FIRST: According to the emails provided by the complainant, it is established that on 20/04/23, a breach of confidentiality of personal data occurred when an email was sent on behalf of the City Council of San Cristóbal de La Laguna, disclosing the email addresses of 493 individuals who provided their personal data when registering for the sporting event XXII MEDIA MARATÓN CIUDAD DE LA LAGUNA organized by the Autonomous Sports Organization of San Cristóbal de La Laguna (hereinafter, OAD), which was to take place on Sunday, April 23, 2023, at 09:00 hours. The aforementioned email dated 20/04/23 was sent to 493 recipients from the email address \*\*\*EMAIL.1 and bore the signature of B.B.B. It is noted that the email addresses of these 493 individuals appeared as recipients of the email and not in blind copy. The subject of the email was to inform about the "Schedule for picking up race numbers for the XXII MEDIA MARATÓN CIUDAD DE LA LAGUNA 2023" to the registered participants, and it contained the following content:

"Hello.

IMPORTANT. We communicate the schedules for picking up race numbers and runner bags for the XXII MEDIA MARATÓN CIUDAD DE LA LAGUNA, which will take place this Sunday, April 23, 2023, at 09:00.

Saturday, April 22, at the Plaza de la Catedral from 11:00 am to 20:00.

Sunday, April 23, at the Plaza de la Catedral from 07:00 am to 08:00 am.

We ask that everyone who can easily travel to La Laguna to pick up their race number and bag do so on Saturday to facilitate the collection on Sunday for those coming from farther away.

Thank you very much to all."

SECOND: The complainant also provides two emails dated April 23 and 24, 2023, in which it is established that when asking for explanations about why their email address had been unlawfully published and disclosed to the other 492 recipients of the email, they received a response from the email address \*\*\*EMAIL.1, in which they were apologized to for the error made.

THIRD: It is established that the entity responsible for processing the personal data of the registered

participants in the race that were unlawfully disclosed in the aforementioned email was the City Council of San Cristóbal de La Laguna, which, through its Autonomous Sports Organization, was responsible for organizing the race, determining the purposes and means of processing the personal data of the registered participants, which has been evidenced by the issuance of a Diligence dated May 18, 2024, by which the following documents generated by the Subdirectorate of Data Inspection, obtained from the website of the Autonomous Sports Organization of San Cristóbal de La Laguna, [www.deportelagunero.com](http://www.deportelagunero.com), are attached to the present procedure as Annex I, II, and III, with the content of the same being considered proven for the purposes of this file:

- Annex I. Municipal regulation applicable to the XXII media maratón of the city of La Laguna.
- Annex II. Privacy policy of the website.
- Annex III. Announcement of the call for the XXII media maratón of the city of La Laguna.

FOURTH: It is established that the City Council has not adopted or implemented the appropriate technical and organizational measures to ensure that the personal data provided by the participants of the XXII media maratón of the city of La Laguna have an adequate level of security against the risks of breach of confidentiality that occur when its staff or data processors send mass electronic communications or communications addressed to more than one recipient, such as the obligation to use the blind copy functionality to send emails to more than one recipient, or any other measure that prevents the unauthorized disclosure of email addresses to all participants.

## LEGAL GROUNDS

### I

#### Competence and Procedure

In accordance with and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure. Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

### II

#### Preliminary Issues

The email address is considered personal data whose processing is subject to the regime provided for in the GDPR, as well as its implementing provisions, in accordance with the provisions of Article 4.1, 2, and 7 of the GDPR, which states the following:

"Article 4 Definitions: For the purposes of this Regulation, the following definitions shall apply:

1) 'personal data': any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;"

5/16

a person whose identity can be determined, directly or indirectly, in particular by means of an identifier, such as a name, an identification number, location data, an online identifier, or one or several elements specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person;

2) "processing": any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination, or any other form of enabling access, alignment, combination, restriction, erasure, or destruction; (...)

7) "data controller" or "controller": the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; if Union or

Member State law determines the purposes and means of processing, the controller or the specific criteria for its designation may be established by Union or Member State law (...)

In the present case, according to the provisions of Article 4, paragraphs 1, 2, and 7 of the GDPR, it is noted that the City Council has carried out, in its capacity as controller, a processing of personal data since it has disseminated the email addresses of 493 individuals who provided them when registering for the sporting event XXII MEDIA MARATÓN CIUDAD DE LA LAGUNA organized by the Autonomous Sports Body of San Cristóbal de La Laguna (hereinafter, OAD), which was to take place on Sunday, April 23, 2023, at 09:00 hours.

According to the announcement on the OAD website deportelagunero.com, it is the City Council of San Cristóbal de La Laguna, through the aforementioned OAD, that organizes the race, determining the purposes and means of processing the personal data of the participants, in accordance with the following evidence deduced from its publications regarding the aforementioned race:

- First, the OAD website deportelagunero.com indicates in its privacy policy that this municipal entity is responsible for the personal data of individuals who register for its acts or sporting events, expressly stating that: "The OAD is responsible for the processing; your data will be processed in accordance with current regulations to enable you to use and navigate this website and to process the specific requests you make in this regard."

- On the website of the aforementioned OAD of the City Council, it is acknowledged that the XXII Medio Maratón Ciudad de La Laguna will be held on April 23 (deportelagunero.com), recognizing that it is the one organizing the race and regulating all its aspects.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/16

standards. Note how it establishes the period and method of registration, prices, race route, categories, and other regulations:

"This Wednesday, March 22, 2023, and until April 17, registrations open for the XXII Half Marathon Ciudad de La Laguna, an event organized by the Autonomous Sports Organization, which will take place on April 23. After kicking off with the Night Race, this athletic event comes to offer a longer distance for long-distance runners. In addition to the 21-kilometer route, spots are also available for 10 and 5 kilometers, respectively. Registrations, which have a maximum quota of 1,400, can be formalized through [www.deportelagunero.com](http://www.deportelagunero.com).

Starting from the Plaza de La Catedral, the 'little sister' (5,000 meters) will pass through iconic places such as Calle la Carrera, La Concepción, Herradores, Trinidad, Viana, Tabares de Cala, etc. A sports 'track' that showcases the charm of a City Heritage of Humanity across all its distances. The 10,000 will touch places like Avenida República Argentina and the surroundings of Vía de Ronda. The same route will be followed for the Half Marathon, which will complete two laps of that circuit.

The regulations, which can be consulted on the registration page ([www.deportelagunero.com](http://www.deportelagunero.com)), include categories from Sub18 to Master 70, including Functional Diversity, which has already made a significant mark in the list of past athletic events. Additionally, there will be cash prizes for the top finishers; a total of 1,540 euros will be distributed. Regarding registrations, the price will depend on the distance, resulting in 15, 12, and 10 euros for the 21, 10, and 5 kilometers, respectively. In addition to the bib number, runners will receive a bag containing a t-shirt, towel, and 'gym sack.'"

- The Registration Regulations for the race published by the OAD of La Laguna detail all the conditions related to it, including how to proceed with the delivery of bib numbers, which also involves defining the purposes and means of processing personal data for the purposes of Article 4.7 of the GDPR.

According to the aforementioned Article 4.7 of the GDPR, what is relevant to determine the responsibility for sending this email without a blind copy and the lack of measures to prevent it is to determine who has set the purposes and means of processing. In light of this evidence, there is no doubt that the City Council, through the OAD of La Laguna, was the organizer of the race and declared itself responsible for the processing of personal data of the participants registered in the race, determining the purposes and means by which the processing should be carried out, as well as the

conditions of the race, among which was to communicate the place and date for the collection of bib numbers.

In this case, the complaint was directed against B.B.B., because the mass email that disclosed the email addresses of 493 participants in the race, including the complainant, was sent from the address [adelanteeventos@gmail.com](mailto:adelanteeventos@gmail.com) and the signature footer indicated B.B.B. However, this does not imply that the responsibility for the processing of the personal data that were revealed by that email falls on the person whose name appears as

C/ Jorge Juan, 6  
[www.aepd.es](http://www.aepd.es)  
28001 – Madrid  
[sedeagpd.gob.es](mailto:sedeagpd.gob.es)  
7/16

sender of the email. Whenever Article 4.7 of the GDPR states that the one who has set the purposes and means of processing will always be responsible for the processing, and not those individuals or entities that execute the instructions set by it (whether as staff of the Town Hall itself, or as a data processor contracted by it). That is, the data controller will be liable for the acts carried out by its public employees or the potential processors it hires to perform part of the functions that fall under the Town Hall's competence, which require carrying out operations of processing personal data that the data subjects have provided to the controller (in this case, to the OAD of La Laguna, belonging to the Town Hall).

According to extensive European jurisprudence, the criterion has been consolidated whereby, in matters of personal data protection, the one who sets the purposes and means of processing personal data will be the sole responsible party for the processing operations carried out by individuals acting under their instructions, whether they are staff of the Town Hall itself or processors managing any of the necessary procedures or actions of the processing that involve accessing and using such personal data. As in this case, it would be the procedure or action of communicating the schedule and location for the delivery of race bibs, which has been carried out via the email referred to in this file.

It is worth noting, as an example of this jurisprudence, the Judgment of the Court of Justice of the European Union, dated December 5, 2023, issued in case C-683/21 (*Nacionalinis visuomenės sveikatos centras*), which states:

“Since, as indicated in paragraph 36 of this judgment, a data controller is responsible not only for all personal data processing that it carries out itself but also for processing carried out on its behalf, an administrative fine may be imposed on that controller under Article 83 of the GDPR in a situation where personal data is subject to unlawful processing and where it is not the controller, but a processor it has engaged, who has carried out the processing on its behalf.”

From the evidence obtained through the issuance of the aforementioned Diligence and the emails provided by the complainant, it is clear that in this case there is no doubt that B.B.B. was acting on behalf of the Town Hall when it sent the email dated 04/20/23 referred to in this file, given that:

- The email in question aimed to execute part of the functions assumed for the organization of the race by the OAD of the Town Hall, as its purpose was to communicate the days and location for the delivery of bibs to its participants, specifying the dates, times, and location, as indicated in the Race Registration Regulations (April 22 and 23, 2023, at the Plaza de la Catedral). This required access to the personal data of the participants.

- From the privacy policy published at the headquarters of the OAD of La Laguna, as well as from the provisions in the Regulations and Call for the race, it is inferred that the participants of the race provided their address of C/ Jorge Juan, 6.

[www.aepd.es](http://www.aepd.es)  
28001 – Madrid  
[sedeagpd.gob.es](mailto:sedeagpd.gob.es)  
8/16

email to the OAD of La Laguna (and not to “Adelante eventos” or B.B.B.), as this information was included in the registration form and was necessary to register for the race, accessing the OAD registration page of the City Council ([www.deportelagunero.com](http://www.deportelagunero.com)).

-

The sender of the email would not have been able to access the email addresses of the 493 participants if the OAD of the City Council had not granted him access to this personal data of the participants, by assigning him part of the organizational functions of the race that corresponded to him. Specifically, the email address was necessary for him to send the communications that needed to be made in the context of the organization of the race. Communications that involve operations of personal data processing since they require collecting/extracting the data of the email and/or postal address of the participants, and using it to send the mentioned emails, which involves carrying out various operations of personal data processing that are subject to the principles and requirements of the GDPR, among which is the prohibition of unlawfully disclosing the personal data that a participant has provided to the data controller to other participants of the race.

Therefore, it was and is the responsibility of the OAD of the City Council to ensure that there are no unlawful disclosures of the data provided by the participants, by the data processors or persons in their service, as well as to analyze the risks arising from the processing of the personal data that the participants have provided upon registration (such as their email address), and to foresee the appropriate and proportionate organizational and technical security measures to these risks, to ensure that their rights and freedoms are not violated.

Consequently, given the municipal ownership of the OAD, and the unique public legal personality of the local administration, it is the City Council of San Cristóbal de La Laguna that is the presumed responsible party to which this sanctioning procedure should be addressed in accordance with the provisions of Article 70.1 a) of Organic Law 3/2018, of December 5, on the protection of personal data and guarantee of digital rights (hereinafter, LOPPDD):

“Article 70. Responsible subjects.

1.

They are subject to the sanctioning regime established in Regulation (EU) 2016/679 and in this organic law: a) The controllers of the processing. b) The processors of the processing. c) The representatives of the controllers or processors of the processing not established in the territory of the European Union. d) The certification entities. e) The accredited entities supervising the codes of conduct. (...)”.

III

Non-compliance with Article 5.1.f) of the GDPR

Article 5.1.f) “Principles relating to processing” of the GDPR establishes that:

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

9/16

“1. Personal data shall be: (...)

f) processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures (“integrity and confidentiality”).”

Article 4, paragraph 12 of the GDPR broadly defines “personal data security breaches” (hereinafter referred to as personal data security breach) as “any breach of security that leads to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.”

In the present case, a personal data security breach has occurred, categorized as a confidentiality breach; as a result of sending an email on April 20, 2023, to the claimant that included personal data of many other individuals. Specifically, 493 email addresses, including that of the claimant, appeared as recipients of the email, being visible to all of them, without using the blind carbon copy functionality. This implies a violation of the Principle of Confidentiality contained in Article 5.1.f) of the GDPR, since the aforementioned email has resulted in unauthorized communication of the email addresses of all individuals appearing as recipients of the email sent to communicate the schedule and location for the delivery of race bibs for the event organized by the City Council.

Given that the recipients listed in such an email have not requested nor have the legitimacy to know the email addresses of the other participants, beyond those cases regulated by personal data protection legislation.

In conclusion, in accordance with the proven facts in the present procedure, it is considered that the facts presented violate the provisions of Article 5.1.f) of the GDPR, for unlawfully disclosing the email addresses of the 493 recipients that appear visible in the aforementioned email.

IV

Classification and qualification of the infringement of Article 5.1.f) of the GDPR

In accordance with the proven facts in the present sanctioning procedure, it is considered that the known facts constitute an infringement, attributable to the respondent, for violating the Principle of Confidentiality provided for in Article 5.1.f) of the GDPR.

Specifically, if the reality of the reported facts is confirmed, the aforementioned infringement of Article 5.1.f) of the GDPR could constitute the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides (the underlining is ours):

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/16

"Violations of the following provisions shall be sanctioned, in accordance with section 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

For the purposes of the limitation period for violations, Article 72 "Very Serious Violations" of the LOPDGDD may be applied, which states (the underlining is ours):

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following violations are considered very serious and shall be subject to a three-year limitation period: those that constitute a substantial breach of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

V

Non-compliance with Article 32 of the GDPR

Article 32 "Security of Processing" of the GDPR establishes the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others: a) the pseudonymization and encryption of personal data; b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services; c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident; d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

The controller and the processor shall take measures to ensure that any person acting under the

authority of the controller or the processor...

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

11/16

and have access to personal data may only process such data following the instructions of the controller, unless required to do so by Union law or the law of the Member States.”

It should be noted that the GDPR has represented a paradigm shift, centered around essential pillars such as the principles of proactive responsibility and risk management from the design stage and by default, as well as accountability, which are the foundations of the new regulation, aimed at further protecting the rights and freedoms of data subjects in terms of data protection.

Based on this new conception, the aforementioned provision does not establish a list of security measures applicable according to the data being processed, but rather establishes that the controller and the processor are “proactive” responsible parties who will apply technical and organizational measures that are appropriate to the risk posed by the processing they carry out (as they are the ones who know it in detail), taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks of probability and severity for the rights and freedoms of the data subjects.

Furthermore, it is noteworthy that Article 32 of the GDPR explicitly states that security measures must be adequate and proportionate to the detected risk, indicating that the determination of technical and organizational measures must be carried out considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification processes (not audits), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by the processing of data, as a consequence of the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damage.

In this same vein, Recital 83 of the GDPR states that “(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption.

These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which could particularly cause physical, material, or immaterial damage.”

The responsibility of the City Council regarding non-compliance with this provision is determined because it is responsible for making decisions aimed at effectively adopting and implementing the technical and organizational measures.

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

12/16

appropriate to ensure an adequate level of security relative to the risk to ensure the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident.

In this case, it has been established that at the time of sending the email referred to in this procedure, the OAD of the City Council, which collected the personal data of the participants who registered for the half marathon, had not foreseen “reasonable security measures based on the estimated possible



risks" referred to in Article 32 of the GDPR, since among these risks was undoubtedly the risk of unauthorized disclosure of the email addresses of the participants when sending electronic communications to more than one recipient.

Therefore, given the risk of unlawful disclosure, their duty as the data controller of this personal data was to foresee it and adopt "appropriate technical and organizational measures to ensure a level of security appropriate to the risk," aimed at preventing any member of the organization (or data processor to whom the personal data of the participants have been provided) from sending emails addressed to more than one recipient without using the blind carbon copy functionality.

In conclusion, in light of the proven facts in this sanctioning procedure, it is considered that the known facts violate what is established in Article 32 of the GDPR, for failing to foresee adequate security measures against the risk of unlawful disclosure posed by sending emails to multiple recipients without using the blind carbon copy functionality.

VI

Typification and qualification of the infringement of Article 32 of the GDPR

By virtue of what is indicated in the previous legal basis, in accordance with the proven facts in this sanctioning procedure, it is considered that the known facts constitute an administrative infringement for violation of Article 32 of the GDPR, for not establishing adequate security measures that would prevent breaches such as the one that occurred in this case.

If this fact is confirmed, the aforementioned infringement of Article 32 of the GDPR could constitute an infringement classified under Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides the following (the underlining is ours):

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

5) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](http://sedeagpd.gob.es)

13/16

For the purposes of the limitation period for this infringement, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a limitation period of two years for infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following: ...

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679."

VII

Proposal for sanction

Article 83 "General conditions for the imposition of administrative fines" of the GDPR in its paragraph 7 establishes:

"Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

Furthermore, Article 77 "Regime applicable to certain categories of controllers or processors" of the LOPDGDD provides that:

"1. The regime established in this article shall apply to the processing for which they are responsible or to which they are assigned:

a) The constitutional bodies or those with constitutional relevance and the institutions of the autonomous communities analogous to them.

- b) The judicial bodies.
- c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that make up the Local Administration.
- d) The public bodies and entities of public law linked to or dependent on the Public Administrations.
- e) The independent administrative authorities.
- f) The Bank of Spain.
- g) The public law corporations when the purposes of the processing relate to the exercise of public law powers.
- h) The public sector foundations.
- i) The Public Universities.
- j) The consortia.
- k) The parliamentary groups of the General Courts and the Legislative Assemblies of the autonomous communities, as well as the political groups of the Local Corporations.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution declaring the infringement and establishing, where appropriate, the

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

14/16

measures that should be adopted to cease the conduct or correct the effects of the infringement that may have been committed, with the exception of that provided for in Article 58.2.i of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016.”

The resolution will be notified to the data controller or processor, to the body to which it hierarchically depends, if applicable, and to the affected parties who had the status of interested parties, if applicable.

3. Without prejudice to what is established in the previous section, the data protection authority will also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied will be those established in the legislation on disciplinary or sanctioning regimes that are applicable.

Furthermore, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is proven, the resolution imposing the sanction will include a reprimand naming the responsible position and will order publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions related to the measures and actions referred to in the previous sections must be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article will be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.”

Since the data controller belongs to the local administration, once the commission of the aforementioned infringements is confirmed, it is the responsibility of the City Council of San Cristóbal de La Laguna to issue a resolution declaring the infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR.

## VIII

### Adoption of corrective measures

If the infringement is confirmed, it may be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with what is established in the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...”

The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

In this case, the measure will consist of adopting and demonstrating to this Agency within a period of 1 month the necessary technical and organizational measures to prevent the sending of communications or emails to multiple recipients by personnel of the City Council or by individuals or entities acting in accordance with

15/16

Your instructions must be carried out without using the "BCC" functionality or any other that prevents the email address of each recipient from being disclosed.

It is warned that failure to comply with any possible order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, and such conduct may lead to the initiation of further administrative sanctioning procedures.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE that the AYUNTAMIENTO DE SAN CRISTÓBAL DE LA LAGUNA, with NIF P3802300H, has infringed the provisions of Article 5.1.f) of the GDPR and Article 32 of the GDPR, an infringement classified in Article 83.5.a) of the GDPR and Article 83.4.c) of the GDPR.

SECOND: TO ORDER the AYUNTAMIENTO DE SAN CRISTÓBAL DE LA LAGUNA, with NIF P3802300H, to comply with the provisions of Article 58.2.d) of the GDPR, within 1 month from the date this resolution becomes final and enforceable, to demonstrate that it has proceeded to comply with the following corrective measures:

- Adopt and demonstrate to this Agency within 1 month the necessary technical and organizational measures to prevent the sending of communications or emails to multiple recipients by personnel of the Ayuntamiento or by individuals or entities acting in accordance with their instructions, without using the "BCC" functionality or any other that prevents the email address of each recipient from being disclosed.

THIRD: TO NOTIFY this resolution to the AYUNTAMIENTO DE SAN CRISTÓBAL DE LA LAGUNA.

FOURTH: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and in section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](http://sedeagpd.gob.es)

16/16

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the final resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal.

If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative

appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](http://sedeagpd.gob.es)